08 Cybersecurity Law and Ethics

1. Introduction

Cybersecurity law and ethics explain how to use computers, networks, digital information and security tools legally and responsibly.

A cybersecurity professional must protect systems, respect privacy, follow applicable laws and obtain permission before testing systems.

Example: A penetration tester must receive authorization from a company before testing its website for vulnerabilities.

2. Legal Hacking vs Ethical Hacking

What is ethical hacking?

Ethical hacking is the authorized process of testing computers, networks or applications to find security weaknesses before criminals exploit them.

What is legal hacking?

In this context, legal hacking means security testing performed within applicable laws, valid authorization and agreed testing conditions. Merely calling an activity “ethical hacking” does not make it legal.

Ethical and authorized activity	Unauthorized activity
Testing a website with written permission	Testing a website without permission
Scanning an approved lab machine	Scanning systems outside the agreed scope
Reporting vulnerabilities responsibly	Publishing sensitive data or exploiting it for personal gain
Keeping evidence confidential	Sharing private information without authorization

Example

A company authorizes a security professional to test its website. The professional identifies a SQL injection vulnerability, documents the finding and reports it to the company.

This is authorized security testing when performed within the agreed scope.

Remember: A good cybersecurity professional protects systems rather than misusing access.

3. Written Authorization

Written authorization is documented permission from the system owner or an authorized representative to conduct security testing.

It establishes that the testing is approved and clarifies what the tester may do.

Why is written authorization important?

- Helps demonstrate permission.
- Defines the approved systems and activities.
- Reduces misunderstandings between the tester and the organization.
- Helps prevent accidental testing of unrelated systems.
- Provides a reference if questions arise during the assessment.

What should authorization contain?

1. Name of the organization and authorized contact.
2. Name of the tester or testing team.
3. Target systems, websites or IP addresses.
4. Approved testing dates and times.
5. Permitted and prohibited activities.
6. Emergency contact details.
7. Data-handling and reporting requirements.
8. Approval from an authorized person.

Example

An organization authorizes a tester to assess test.example.com from 10 AM to 4 PM on a specified date. The tester must not test any other domain.

Important: Permission to test one website does not automatically authorize testing its hosting provider, connected services, other domains or third-party systems.

4. Scope of Testing

Scope defines exactly which systems and activities are included in a security assessment.

It helps the tester understand the limits of the assignment.

Types of scope

Scope item	Example
In-scope assets	test.example.com and a specified test server
Out-of-scope assets	Production payment systems and third-party services
Allowed activities	Approved vulnerability scanning and manual testing
Prohibited activities	Destructive testing or denial-of-service testing
Testing period	Approved dates and time window
Reporting requirements	A report containing findings, evidence and recommendations

Example

A company allows testing of its development website but excludes its live banking application.

The tester must test only the development website.

If a vulnerability appears to affect an out-of-scope system, the tester should stop before testing that system and seek further authorization.

Remember: Scope tells you where and how you are allowed to test.

5. Rules of Engagement (RoE)

Rules of Engagement are the agreed instructions that explain how a security assessment must be conducted.

They help the tester perform work safely, consistently and within approved limits.

Important elements of RoE

- Testing objectives.
- Approved targets and methods.
- Start and end dates.
- Testing hours.
- Permitted tools and techniques.
- Prohibited activities.
- Emergency stop procedure.
- Communication and escalation contacts.
- Data protection and evidence-handling requirements.
- Reporting format and deadlines.

Example

During a penetration test, the organization prohibits denial-of-service attacks because they could interrupt business services. The tester must follow this restriction.

Scope vs Rules of Engagement

Scope	Rules of Engagement
Defines what is included in testing	Defines how testing must be performed
Identifies approved and excluded assets	Specifies testing methods, restrictions and procedures
Example: A development website is in scope	Example: Testing must stop if service availability is affected

6. Responsible Vulnerability Disclosure

Responsible vulnerability disclosure is the process of reporting a security weakness to the affected vendor or organization so it can investigate and fix the issue.

The goal is to reduce harm and protect users.

In India, CERT-In provides a Responsible Vulnerability Disclosure and Coordination Policy. It describes how vulnerability reports can be submitted and coordinated with affected vendors. See the official policy: https://www.cert-in.org.in/RVDCP.jsp

Steps for responsible disclosure

1. Identify a possible vulnerability within an authorized environment.
2. Verify the finding safely without accessing unnecessary information.
3. Record relevant technical details and minimal supporting evidence.
4. Report the issue privately through the vendor's or organization's designated security contact.
5. Cooperate with the investigation and remediation process.
6. Allow reasonable coordination before any public disclosure.
7. Follow the organization's disclosure policy and applicable legal requirements.

Example

A researcher discovers that an authorized test application exposes sensitive information. The researcher documents the issue and reports it privately to the organization rather than publishing the exposed information online.

What should you avoid?

- Accessing or downloading unnecessary personal information.
- Changing or deleting data.
- Publishing credentials or sensitive evidence.
- Threatening the organization.
- Demanding money in exchange for keeping a vulnerability secret.
- Testing beyond the authorized scope.

Remember: Discover, document, report and cooperate.

7. Privacy and Evidence Handling

Privacy means respecting people's personal information and protecting it from unauthorized access or disclosure.

Evidence handling means collecting, preserving, documenting and storing digital evidence in a way that helps maintain its integrity and reliability.

These principles are especially important in Digital Forensics and Incident Response (DFIR).

Privacy principles

- Access only the information necessary for the authorized task.
- Do not share confidential information with unauthorized people.
- Protect personal data and credentials.
- Store reports and evidence securely.
- Follow applicable privacy laws and organizational policies.
- Delete or return evidence according to authorized retention requirements.

Evidence-handling steps

1. **Identify:** Locate relevant digital evidence.
2. **Collect:** Acquire evidence using an approved method.
3. **Preserve:** Prevent unauthorized changes to the evidence.
4. **Document:** Record who collected it, when, where and how.
5. **Verify integrity:** Use cryptographic hashes such as SHA-256 where appropriate.
6. **Store securely:** Restrict access and maintain an evidence log.
7. **Transfer carefully:** Document every transfer and maintain the chain of custody.

What is chain of custody?

The chain of custody is a documented record of who collected, handled, transferred and stored evidence throughout its lifecycle.

It helps establish that evidence has been handled properly and that unexplained changes have not occurred.

Example

An incident responder collects a disk image from an affected computer. The responder records the acquisition details, calculates a SHA-256 hash and stores the evidence securely with restricted access.

The hash can later be recalculated to check whether the image has changed.

Remember: Preserve evidence, protect privacy and document every important action.

8. Indian Cybercrime Law

Information Technology Act, 2000

The Information Technology Act, 2000, as amended, is a key Indian law addressing electronic records, electronic transactions and various computer-related offences.

Official source: India Code — https://www.indiacode.nic.in/indiacode/handle/123456789/1999?locale=en

Cybersecurity professionals should understand that unauthorized access, data damage, identity theft and other activities may attract legal consequences depending on the facts and applicable provisions.

Important sections for cybersecurity students

Section	Simple explanation	Example
Section 43	Addresses specified unauthorized acts involving computer systems, such as unauthorized access, copying data or damaging computer resources, and provides for compensation under its terms	A person accesses a system without permission and copies data
Section 66	Addresses acts covered by Section 43 when committed dishonestly or fraudulently, subject to the section's requirements	A person dishonestly or fraudulently accesses or damages a computer resource
Section 66C	Addresses identity theft involving fraudulent or dishonest use of another person's electronic signature, password or other unique identification feature	A person fraudulently uses another person's password to impersonate them

Official Act text: https://www.indiacode.nic.in/bitstream/123456789/15413/1/20_the_information_technology_act%2C_2000%283%29.pdf

Important points

- Section 43 and Section 66 are related but are not identical.
- Section 66 requires the dishonest or fraudulent element specified in that section.
- Section 66C concerns identity theft; it is not a general provision covering every type of hacking.
- The legal outcome depends on the facts, the applicable law and the evidence.
- Other laws may also apply depending on the conduct, the data involved and the circumstances.

These notes are for basic educational awareness, not legal advice. Consult the current official legislation or a qualified legal professional for a specific case.

9. Why Is Permission Required Before Testing Systems?

Security testing can involve activities such as scanning ports, identifying services, checking vulnerabilities and attempting controlled exploitation.

Even if your intention is to learn, performing these activities on systems without authorization can create legal, privacy and operational risks.

Main reasons

1. **Legal compliance:** Authorization helps establish the permitted basis for testing.
2. **Privacy protection:** Prevents unauthorized access to personal or confidential information.
3. **Business continuity:** Avoids disrupting real services.
4. **Data protection:** Reduces the chance of modifying or deleting information.
5. **Clear boundaries:** Defines which systems can be tested.
6. **Professional responsibility:** Demonstrates respect for system owners and users.

Example

You are learning Nmap in Kali Linux.

- Scanning your own Ubuntu VM in an isolated lab: appropriate when configured and used safely.
- Scanning a company's server without permission: may be unauthorized and could create legal or operational problems.
- Testing a company's server after receiving written authorization: permitted only within the approved scope and rules.

Important: A publicly accessible website is not automatically authorized for penetration testing.

10. Ethical Hacking Checklist

Before starting a security test, confirm the following:

- I have permission from an authorized person.
- I know the exact in-scope assets.
- I know which activities are prohibited.
- I understand the testing dates and time window.
- I know how to report an unexpected issue.
- I will avoid unnecessary access to personal or confidential data.
- I will preserve and document evidence appropriately.
- I will report findings responsibly.
- I will stop if the test exceeds the approved scope or creates unexpected harm.

11. Conclusion

Cybersecurity professionals must combine technical skills with legal awareness and ethical responsibility. Written authorization, a clear scope, Rules of Engagement, responsible disclosure and proper evidence handling help protect both systems and people.

In India, the Information Technology Act, 2000, as amended, contains important provisions relevant to computer-related offences and identity theft. Understanding these principles helps SOC analysts, penetration testers and incident responders work professionally and responsibly.